

Network Security

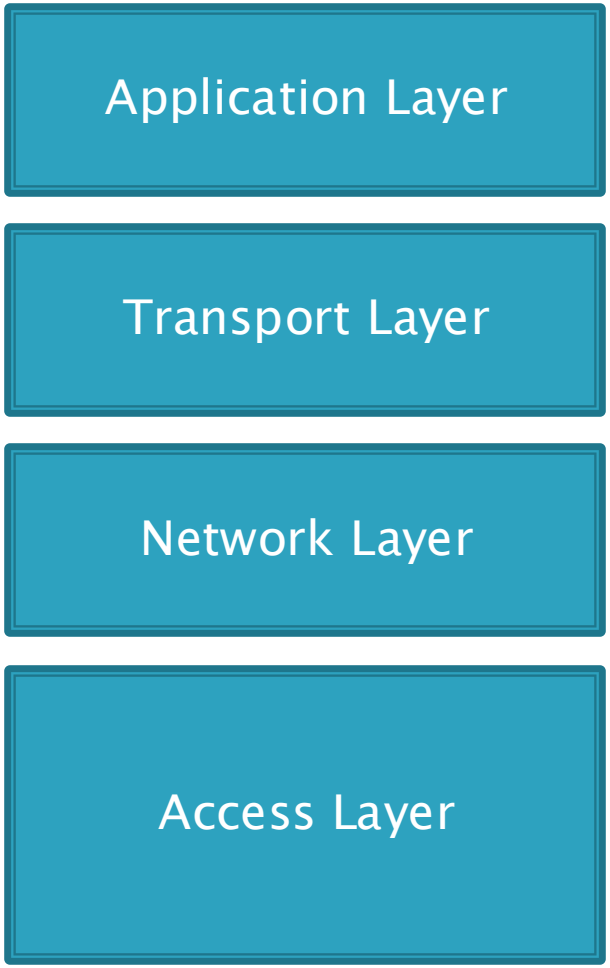
Theory Class Nº2

Jorge Sa Silva
sasilva@deec.uc.pt
University of Coimbra
Portugal

Outline

- Areas of Security
- Vulnerabilities
- Attacks
- Risks
- Defences
- Kahoot
- Basics of cryptography

TCP/IP


Application Layer
Transport Layer
Network Layer
Access Layer

Areas of Security

- Security against disasters
- Security against foreseeable failures
- Security against unauthorized activities

Security against disasters

- Environmental disasters
  - Earthquakes, fires, floods, ...
- Politic disasters
  - Terrorist attacks, riots, ...
- Material disasters
  - Irreparable degradation, theft of equipment, ...

Measures against disasters

- Equipment redundancy
- Information redundancy
- Location redundancy
- Backup
  - Frequency?

➢ Each case is different, and the cost-benefit ratio should always be evaluated.

Security against foreseeable failures

- Problems in electricity supply
  - Batteries
  - Electricity generators
- Blocking the execution of applications or operating systems
  - Reset
  - Transactional systems / atomic operation
- Network problems
  - Dynamic routing
  - **TCP** vs **UDP**
  - IntServ, DiffServ

Security against unauthorized activities



- **The focus of this course**

- Internal attacks vs External attacks

- Illicit activities:
  - Access of information,
  - Delete or change information,
  - Abuse of computing resources,
    - Denial of Service, …
  - Vandalism

Vulnerabilities, attacks, risks and measures



- **Vulnerabilities** – flaws in a computer system that weaken the overall security of the device/system and that can be exploited by a threat actor, such as an attacker.
- **Threats** – any circumstances or events that can potentially harm an information system by destroying it, disclosing the information stored on the system, adversely modifying data, or making the system unavailable
- **Attacks** – offensive maneuver to attempt to access data, functions, or other restricted areas of the system without authorization, potentially with malicious intent.
- **Risks** – Damage that can result from successfully executing an attack.
- **Security measures** – set of measures designed to reduce a system's vulnerabilities, detect and defeat attacks, and minimize the risks arising from successful attacks.

Security

- **Confidentiality**: **Safeguards** information from being **accessed** by individuals without the proper clearance, access level, and need to know.
- **Integrity**: Results from the **protection** of unauthorized **modification** or destruction of information.
- **Availability**: Information services are **accessible** when they are needed. Authentication means a security measure that establishes the **validity** of a transmission, message, or originator, or a means of **verifying** an individual's authorization to receive specific categories of information.
- **Non-repudiation**: Assurance the sender of data is provided with **proof of delivery** and the recipient is provided with proof of the sender's **identity**, so neither can later deny having processed the data.

Internet – Be or Not To Be connected?



- Anonymity
- Privacy

Security

- There are no 100% robust defenses
- It's always a cost-benefit exercise
- Use legal mechanisms to obtain dissuasive punishments



Defense in depth vs Perimeter defense

- Defense in depth is important because the traditional perimeter defense model is untenable on its own.
- A perimeter defense philosophy throws as many resources as possible at preventing an attacker from gaining any foothold in the network by hardening its outer edge with firewalls and defenses on individual machines

Security Policy and Security Mechanism

- Security policy (política) – a statement of what is, and what is not, allowed.
  - Principle of least privilege – giving a user account or process only those privileges which are essential to perform its intended function.
- Security mechanism – a method, tool, or procedure for enforcing a security policy.

Security Mechanisms

- Cryptography
- Protocols
- Authentication Services
- Access Control Mechanism
- Confinement
  - Firewalls, DMZ
- Privileged execution mechanisms
- Filters
- Registration
- Audits

Benefits of the “Principle of least privilege”



- Better system stability. When code is limited in the scope of changes it can make to a system, it is easier to test its possible actions and interactions with other applications. In practice for example, applications running with restricted rights will not have access to perform operations that could crash a machine, or adversely affect other applications running on the same system.
- Better system security. When code is limited in the system-wide actions it may perform, vulnerabilities in one application cannot be used to exploit the rest of the machine. For example, Microsoft states “Running in standard user mode gives customers increased protection against inadvertent system-level damage caused by "shatter attacks" and malware, such as root kits, spyware, and undetectable viruses”.[2]
- Ease of deployment. In general, the fewer privileges an application requires, the easier it is to deploy within a larger environment. This usually results from the first two benefits, applications that install device drivers or require elevated security privileges typically have additional steps involved in their deployment. For example, on Windows a solution with no device drivers can be run directly with no installation, while device drivers must be installed separately using the Windows installer service in order to grant the driver elevated privileges.

ISO 17799 -> ISO/IEC 27001 e 27002

- Published in the UK, it is considered the world's first and foremost set of guidelines solely dedicated to organizational system security.
- ISO/IEC 17799 helps companies build safe and secure inter-organizational computer systems.
- ISO/IEC 17799:2005 establishes guidelines and general principles for initiating, implementing, maintaining, and improving information security management in an organization.

ISO/IEC 27001 e 27002

- Business Continuity Planning
- System Access Control
- System Development and Maintenance
- Physical and Environmental Security
- Compliance
- Personal Security
- Security Organization
- Computer and Network Management
- Asset Classification and Control
- Security Policy

ISO 17799 -> ISO/IEC 27001 e 27002



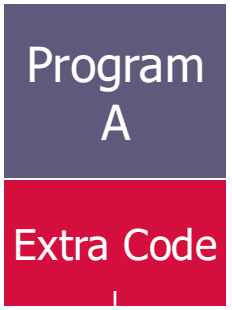
Leading Threats

- Viruses
- Worms
- Hacking
- Phishing
- SPAM Email
- DoS, DDoS
- Trojan Horses / Logic Bombs
- Social Engineering
- Rootkits
- Botnets / Zombies
- …



Viruses

- A virus attaches itself to a program, file, or disk.
- When the program is executed, the virus activates and replicates itself.
- The virus may be benign or malignant but executes its payload at some point (often upon contact).
  - Viruses can cause computer crashes and loss of data.
- In order to recover or prevent virus attacks:
  - Avoid potentially unreliable websites/emails.
  - System Restore.
  - Re-install operating system.
  - Use and maintain anti-virus software.





Malware

- It's malicious software (such as Virus ,Worms & Trojan) , which specifically designed to disrupt or damage computer system or mobile device.

- Hackers use malware for any number of reasons such as, extracting personal information or passwords, stealing money, or preventing owners from accessing their device.

- **Viruses** are programs that attach themselves to a computer or a file and then circulate themselves to other files and to other computers on a network. They usually affect the data on a computer and mobile device either by altering or deleting it.

Malware

- **Worms** unlike viruses do not need the host to attach themselves. They merely make functional copies of themselves and do this repeatedly till they eat up all the available space on the computer's memory.

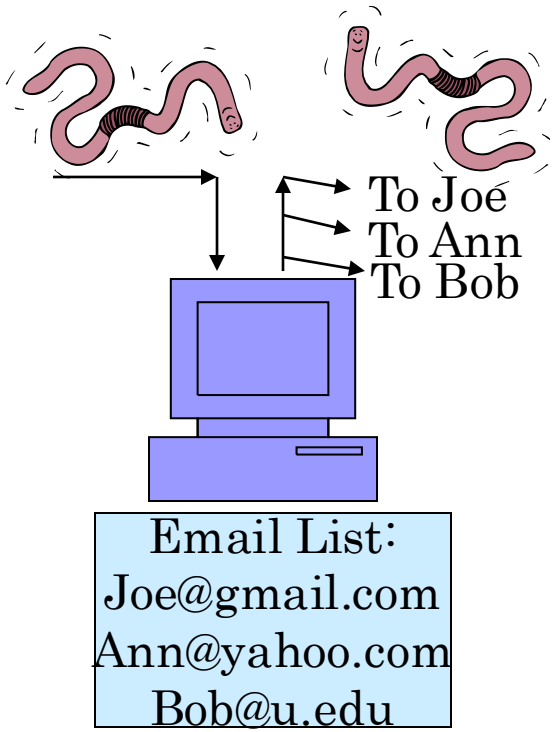
- **Trojan** is a type of malware that pretends to be something useful, helpful, or fun while actually causing harm or stealing data. Trojans are often silently downloading other malware (e.g. spyware, adware, ransomware) on an infected device as well.

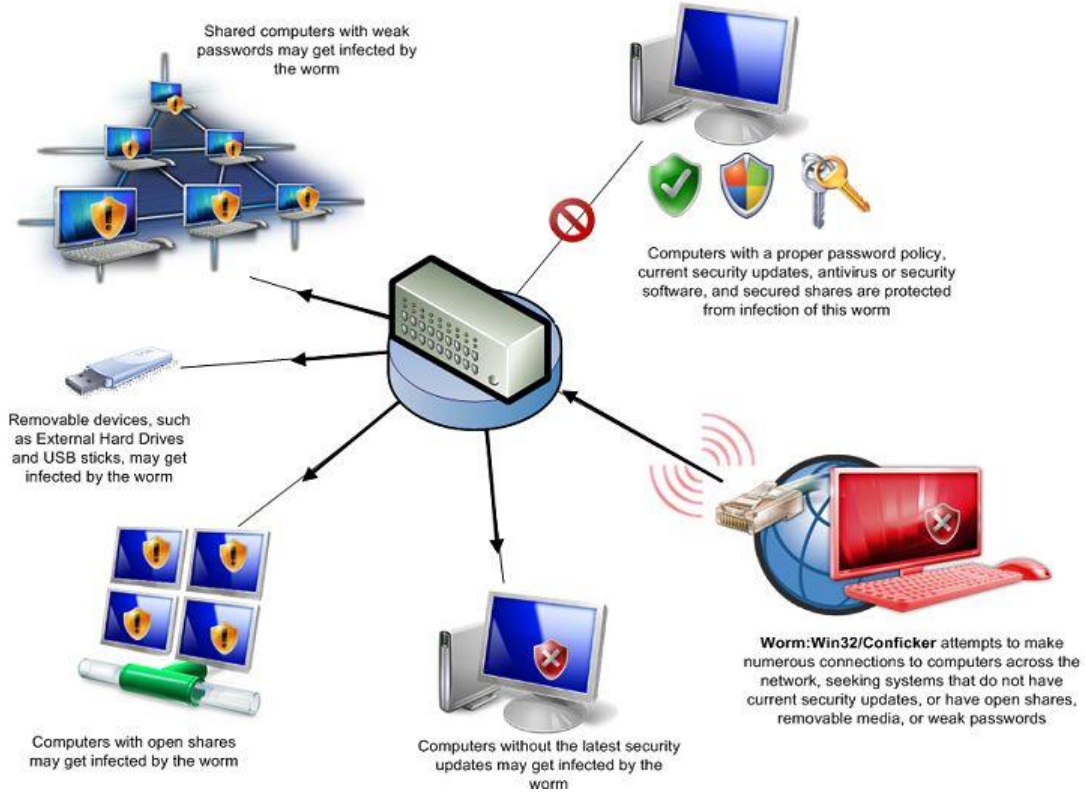
- Trojans can infect you in places where you might not expect it, such as emails, downloads and more. It's always better to be safe than sorry when it comes to avoiding this type of malware.

Worms

Independent program that replicates itself and sends copies from computer to computer across network connections.

Upon arrival, the worm may be activated to replicate.





Spyware

- Spyware is a type of malware that hackers use to spy on you in order to gain access to your personal information, banking details, or online activity. We should protect ourselves by an anti-spyware tool.

Adware

- Adware is a type of malware that bombards you with endless ads and pop-up windows that could potentially be dangerous for your device. The best way to remove adware is to use an adware removal tool.

Hacking



- Hacking in simple terms means an illegal intrusion into a computer system and/or network.
- It is also known as cracking. Government websites are the hot targets of the hackers due to the press coverage, it receives.

Phishing

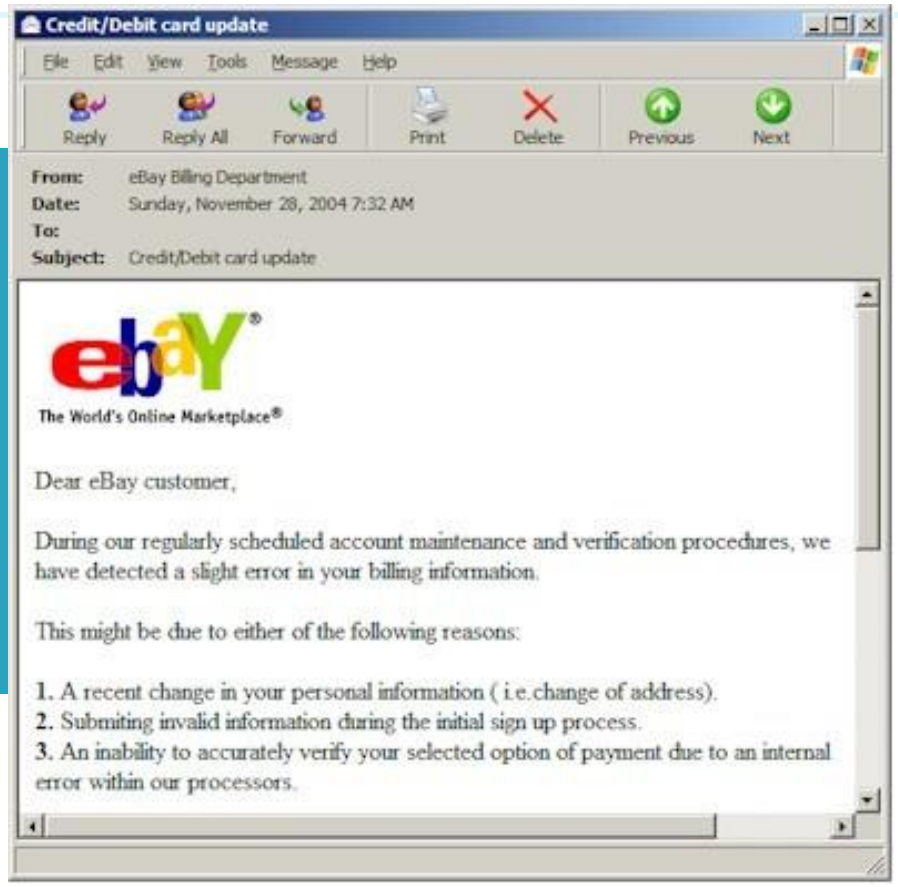
- Phishing is a fraudulent attempt, usually made through email, to steal your personal information.

- Phishing is the attempt to obtain sensitive information such as username, password and credit card details, often for malicious reasons through an electronic communication (such as E-mail).

- A common online phishing scam starts with an email message that appears to come from a trusted source(legitimate site) but actually directs recipients to provide information to a fraudulent web site.

Phishing: Counterfeit Email

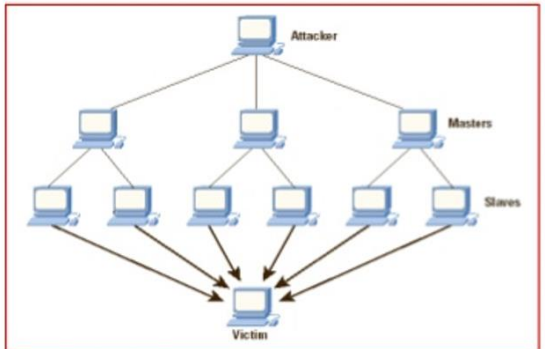
Phishing: A seemingly trustworthy entity asks for sensitive information such as SSN, credit card numbers, login IDs or passwords via e-mail.



Denial of Service

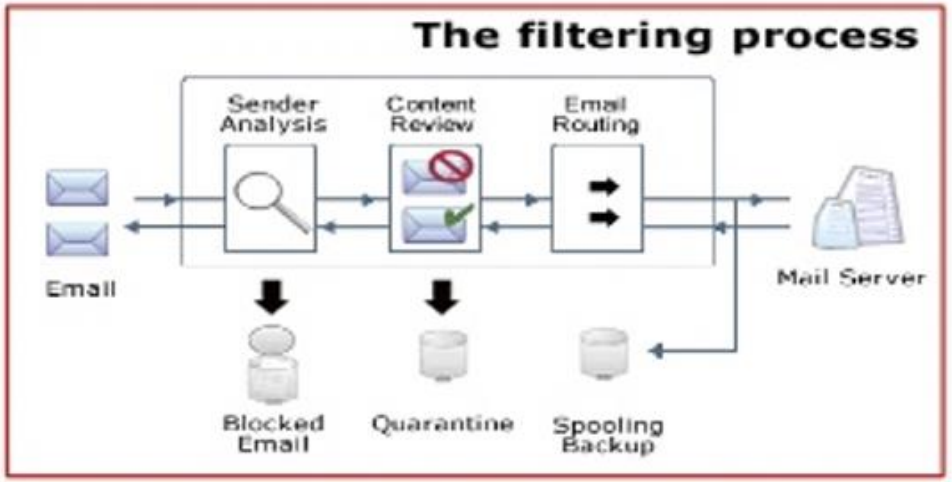
- This is an act by the criminals who floods the Bandwidth of the victims network.
- In the DoS attack, a hacker uses a single internet connection to either exploit a software vulnerability or flood a target with fake request-usually in an attempt to exhaust server resources.
- On the other hand, DDoS attacks are launched from multiple connected devices that are distributed across the internet.
- **DoS = When a single host attacks.**
- **DDoS = when multiple hosts attack simultaneously and continuously.**

Figure of DDoS attack:



SPAM Email

- **Email Spam** is the electronic version of junk **mail**. It involves sending unwanted messages, often unsolicited advertising, to a large number of recipients. **Spam** is a serious security concern as it can be used to deliver Trojan horses, viruses, worms, spyware, and targeted phishing attacks.



Ransomware (resgate)

- Ransomware is as scary as it sounds. Hackers use this technique to lock you out of your devices and demand a ransom in return for access. Ransomware puts you in a sticky situation, so it's best to know how to avoid it.

- Ransomware (a.k.a. rogueware or scareware) restricts access to your computer system and demands that a ransom is paid in order for the restriction to be removed. The most dangerous ransomware attacks are caused by Wannacry, Petya, Cerber and Locky ransomware. The money which suppose to be paid to remove ransomware from your system which is called ransom money.

ATM Skimming

- It is a technique of compromising the ATM machine by installing a skimming device a top the machine keypad to appear as a genuine keypad or a device made to be affixed to the card reader to look like a part of the machine.

- Additionally, malware that steals credit card data directly can also be installed on these devices. Successful implementation of skimmers cause in ATM machine to collect card numbers and personal identification number codes that are later replicated to carry out fraudulent transaction.

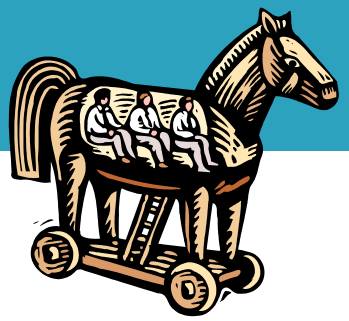
Logic Bombs and Trojan Horses

Logic Bomb: Malware logic executes upon certain conditions. The program is often used for otherwise legitimate reasons.

- Examples:
- Software which malfunctions if maintenance fee is not paid.
- Employee triggers a database erase when he is fired.

Trojan Horse: Masquerades as a benign program while quietly destroying data or damaging your system.

- Download a game: It may be fun but contains hidden code that gathers personal information without your knowledge.



Social Engineering

Social engineering manipulates people into performing actions or divulging confidential information. Similar to a confidence trick or simple fraud, the term applies to the use of deception to gain information, commit fraud, or access computer systems.

Email:
ABC Bank has noticed a problem with your account…

Phone Call:
This is John, the System Administrator. What is your password?



In Person:
What ethnicity are you? Your mother's maiden name?

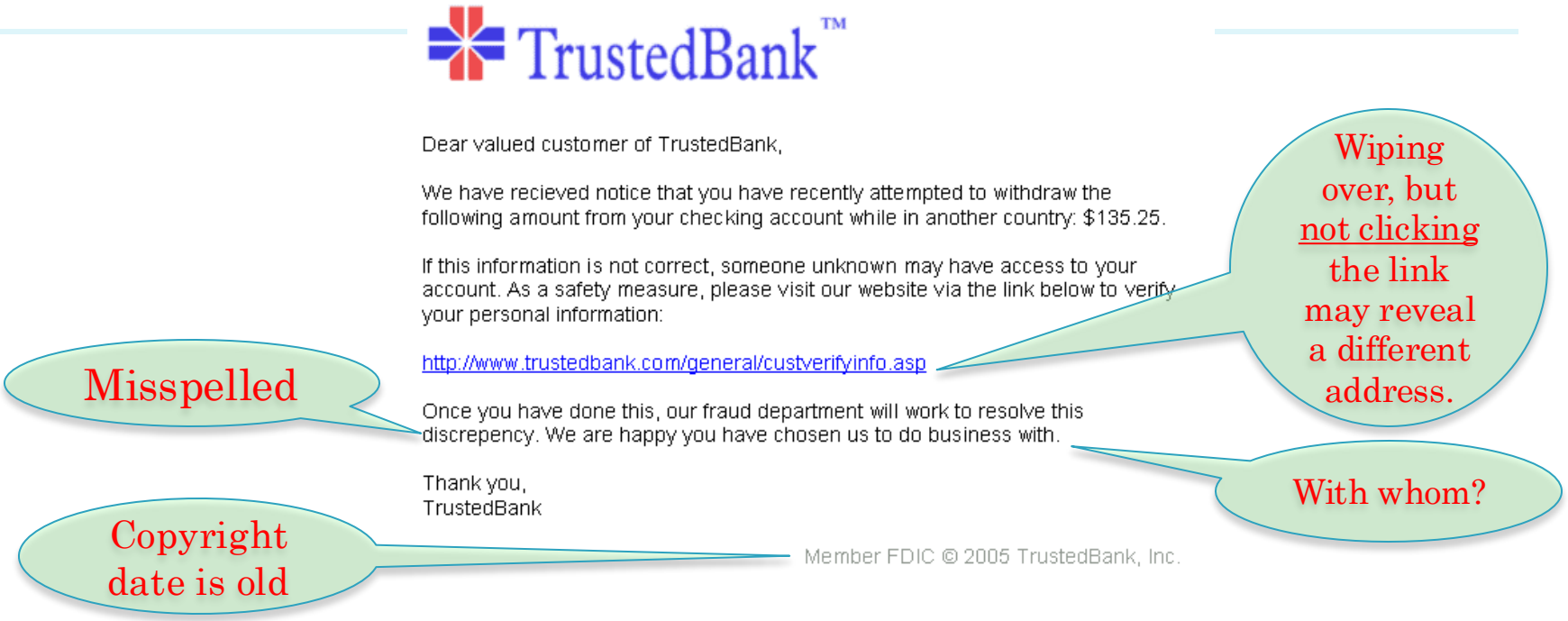


and have some lovely software patches!

I have come to repair your machine…



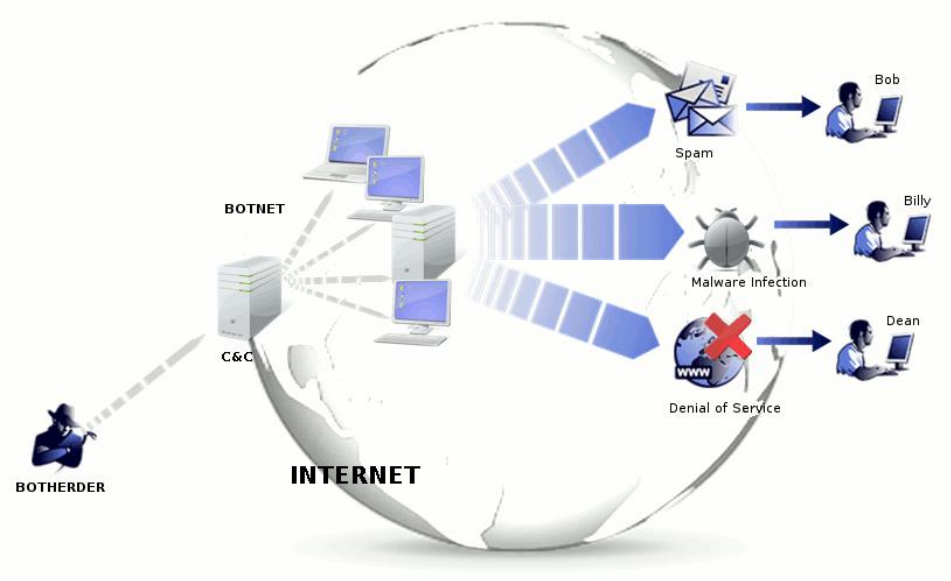
Pharming: Counterfeit Web Pages



The link provided in the e-mail leads to a counterfeit webpage which collects important information and submits it to the owner. The counterfeit web page looks like the real thing and extracts account information

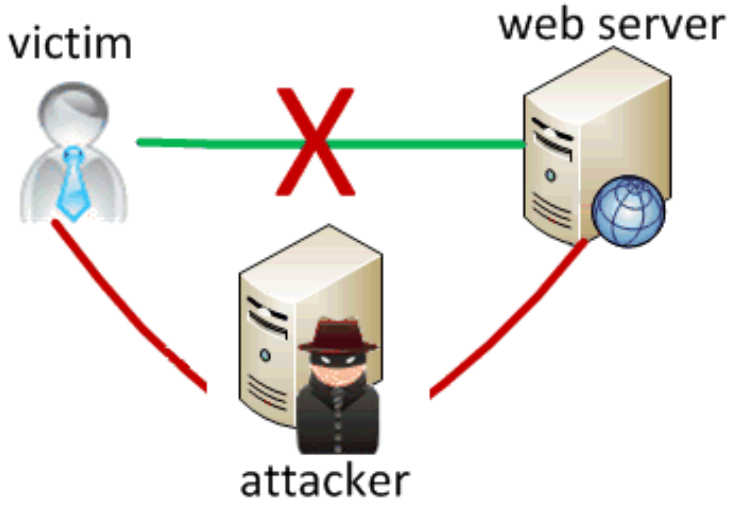
Botnet

- A botnet is a number of compromised computers used to create and send spam or viruses or flood a network with messages as a denial of service attack.
- The compromised computers are called zombies



Man In The Middle Attack

An attacker pretends to be your final destination on the network.
When a person tries to connect to a specific destination, an attacker can mislead him to a different service and pretend to be that network access point or server.



Rootkit

- Upon penetrating a computer, a hacker may install a collection of programs, called a rootkit.
- May enable:
  - Easy access for the hacker (and others)into the enterprise
  - Keystroke logger
- Eliminates evidence of break-in.
- Modifies the operating system.



Types of Cyber Attack by Percentage

(Source-FBI)

• Financial fraud	**11%**
• Sabotage of data/networks	**17%**
• Theft of proprietary information	**20%**
• System penetration from the outside	**25%**
• Denial of Service	**27%**
• Unauthorized access by insiders	**71%**
• Employee abuse of internet privileges	**79%**
• Viruses	**85%**

Outline

- Cryptography



Introduction to Cryptography



- Cryptography is the science of using mathematics to encrypt and decrypt data

- Cryptography is important:
  - Data integrity
  - User authentication
  - Information confidentiality

"A good cryptographic algorithm must be based on a balanced compromise between complexity and usability"

Introduction to Cryptography



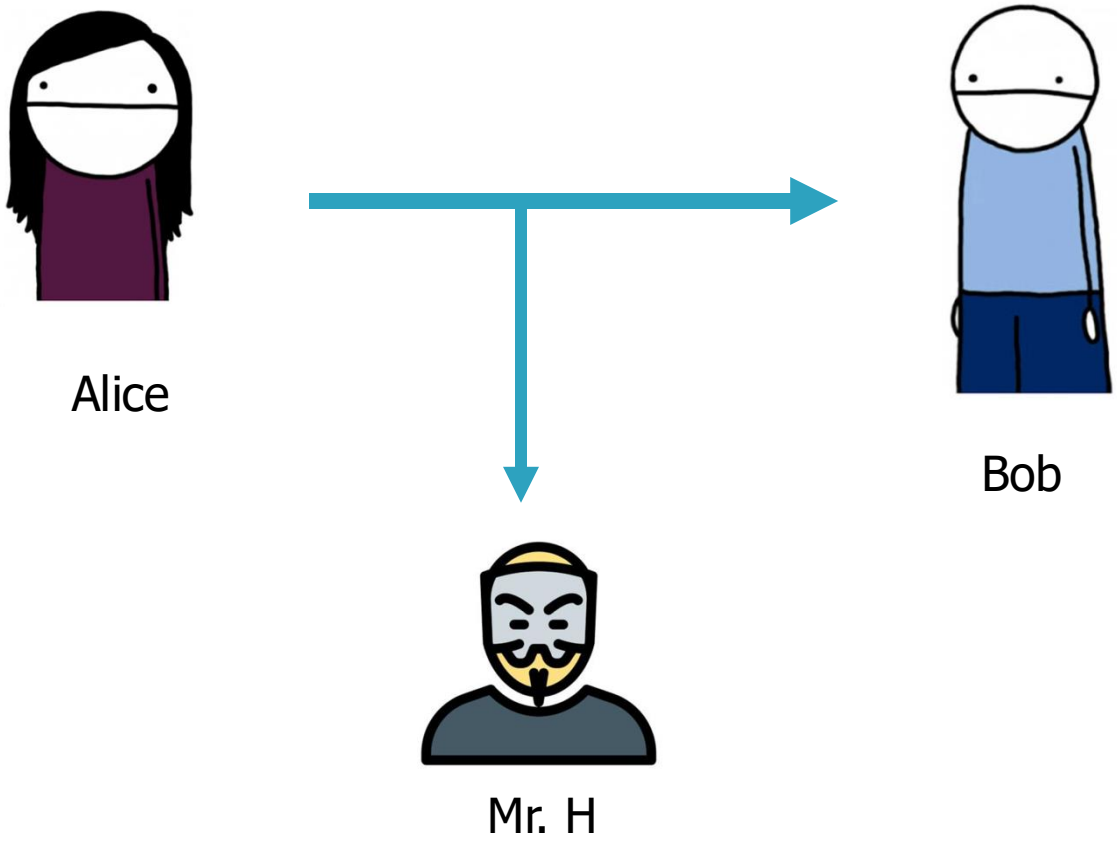
- Bank cards
- Electronic commerce
- Mobile phones
- Internet
- Emails
- Blockchain
- DarkWeb
- ...

Cryptography History

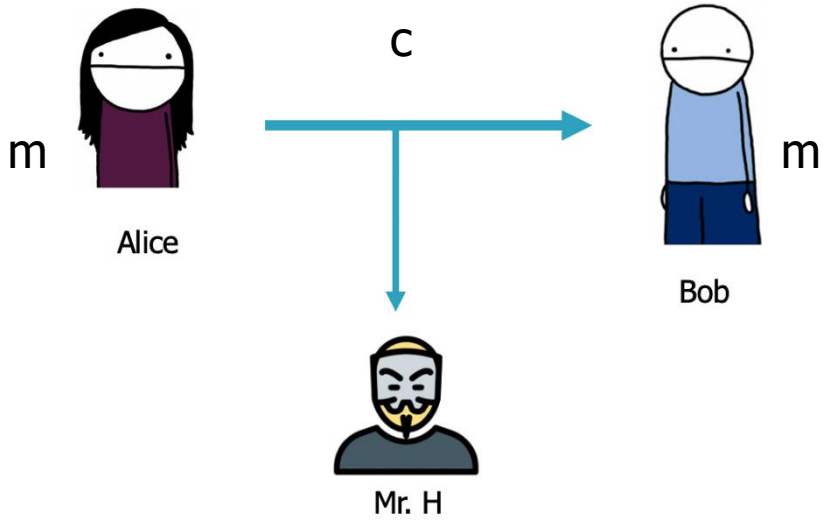
- Cryptography derives its name from a Greek word “Kryptos” which means “Hidden Secrets”.

- Science
  - Maths
  - Computer Science

Cryptography



Cryptography
ex: confidentiality



m – Plain text
k – secret key
E – encryption algorithm
D – decryption algorithm
c – Cypher text

c = E (k , m)
m = D (k, c)
D (k , E (k , m)) = m

Cryptography



"A security system is as strong as its weakest component"

Historic Perspective

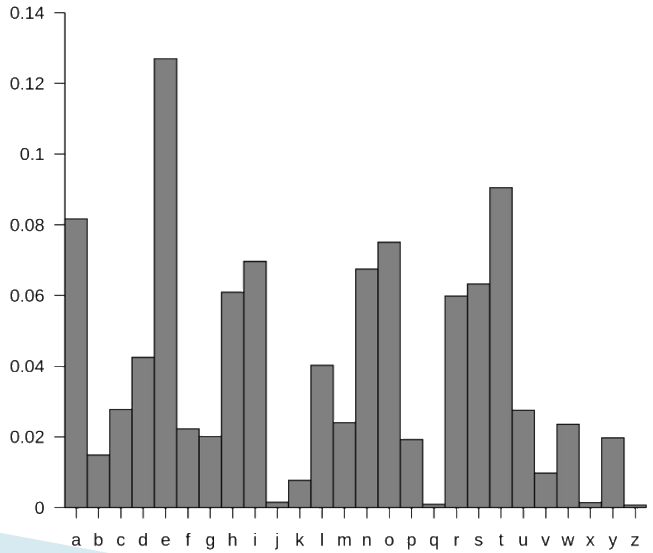
- Caesar cipher - It is a type of substitution cipher in which each letter in the plaintext is replaced by a letter some fixed number of positions down the alphabet.
  - $c_i = E ((m_i + k) \bmod 26)$
  - Problems:
    - Too simple. There are 26 possible keys.
    - The key and the algorithm are related.

➢ Today, an algorithm is only considered "strong enough" if it supports at least 2^{70} possible keys

Substitution technique

- Mono- alphabetic substitution
  - Fixed corresponding table
  - Possible keys (theoretically): 26! = 2^{88}

    - Today, an algorithm is only considered "strong enough" if it supports at least 2^{70} possible keys
    - However the sequence of letters in a word is not random



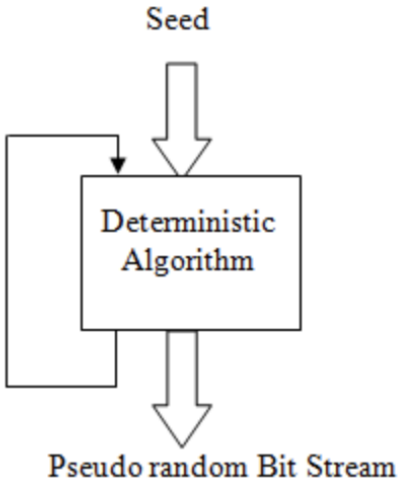
Kerckhoffs's principle

- The security of the encryption scheme must depend only on secrecy of the key and not on the secrecy of the algorithm
- As opposed to "security through obscurity"
- New ciphers and algorithms are not trusted without public scrutiny over years.



Some concepts

- One-way (irreversible) functions
  - Difficult to apply y=f(x)
  - Ex: m mod n = z
- Random and pseudo-random number generators
  - Problem: period
    - May not be a problem if the seed is not known and the period is large enough
  - Need to restart with (random) seeds



Encryption Strength

- Depends on:
  - Algorithm
  - The secrecy of the key
  - The length of the key
  - The initialization vectors
  - How all work together
- Work factor
  - An estimate of the effort and resources it would take to penetrate a cryptosystem
- Strength of protection mechanism should be based in correlation to the sensitivity of the data being encrypted.